

GovSecure AI Chef™

Enterprise AI Governance Recipe Matrix Toolkit

v1.0 - 24 Core Recipes

A practical operational toolkit for governing AI risks, controls, ownership, and assurance across the enterprise.



GovSecure AI Chef™

Visual Table of Contents

Enterprise AI Governance Recipe Matrix Toolkit — v1.0

24 core recipes for governing AI risks, controls, ownership, and assurance across the enterprise.

1		Foundation & Ownership
2		Data & Knowledge Controls
3		Model & Tool Safety
4		Agent & Automation Controls
5		Decision & Human Oversight
6		Assurance, Monitoring & Response

1		Cover & Version Sheet Toolkit identity, subtitle, and versioning.	p. 1
2		Executive Overview Purpose, audience, and business value.	p. 2
3		How to Use the Framework 5-step adoption flow.	p. 3
4		24 Recipe Matrix Six stations, 24 core recipes, and future expansion slots.	p. 4
5		Ownership Model & RACI Roles, accountability, and escalation.	p. 5
6		AI Use Case Intake & Risk Tiering Intake questions, approval path, and risk levels.	p. 6
7		AI System Registry Inventory of systems, owners, vendors, data, and status.	p. 7
8		Policy-to-Control Mapping Policy statements tied to required controls.	p. 8
9		Data, Knowledge & Privacy Controls Classification, provenance, retention, and access.	p. 9
10		Model, Vendor & Agent Safeguards Evaluation, due diligence, permissions, and human oversight.	p. 10
11		Monitoring, Logging & Incident Response Monitoring, drift, incidents, and audit trail.	p. 11
12		Executive Dashboard & Maturity Roadmap Metrics, maturity scoring, and roadmap.	p. 12



Included Templates

- Cover and Version Sheet
- Executive Overview One-Pager
- Framework Adoption Guide
- 24 Recipe Matrix Master Sheet
- AI Governance RACI Matrix
- AI Use Case Intake Form
- AI Risk Tiering Worksheet
- AI System Registry
- Policy-to-Control Mapping Sheet
- AI Data and Knowledge Control Checklist
- Model and Vendor Review Checklist
- Agent Permission and HITL Checklist
- AI Logging and Monitoring Standard
- AI Incident Response Playbook
- Executive AI Governance Dashboard
- Maturity Roadmap Sheet
- Governance Glossary
- Standards Alignment Crosswalk
- AI Governance Evidence Register



GovSecure.ai

AI Governance. Secured. Delivered.



Designed as a practical operational governance toolkit with market-ready presentation quality.

Built from the approved GovSecure AI Chef toolkit outline and template structure.

Executive Overview

GovSecure AI Chef turns AI governance from scattered policies into an operating model with named ownership, risk-tiered intake, mapped controls, evidence expectations, and leadership reporting.

The toolkit is designed for SMB owners, CIO/CISO leaders, compliance teams, and AI governance practitioners who need one framework that can support awareness, implementation, and audit readiness without becoming theoretical sludge.

What is included

- A 24-recipe governance matrix across six stations
- An ownership and RACI model
- AI use-case intake and risk tiering workflow
- AI system registry structure
- Policy-to-control mapping baseline
- Operational guidance for data, model, vendor, agent, monitoring, and incident controls
- A maturity roadmap from 24 to 36 recipes

How to Use the Framework

Use the toolkit in five steps:

1. 1. Identify AI systems and use cases
2. 2. Assess the use case and assign a risk tier
3. 3. Assign owners and supporting functions
4. 4. Implement required controls and record evidence
5. 5. Review quarterly and improve by maturity stage



Toolkit Page Template

Reusable layout for each recipe, checklist, or control page — v1.0

Use this page structure to document any recipe, control, checklist, or governance standard.

	Page Title Enter page title		Page Code ABC-00X		Station Select station
	Primary Owner Enter owner		Risk Tier Low / Med / High		Review Cycle e.g., Annual

1

Purpose

Enter page purpose here. Describe the objective of this page and what it aims to achieve.

2

Risk Addressed

Enter the key governance, security, or privacy risk being managed by this control, recipe, or checklist.

3

Core Control

Enter the required control or governance action. State the mandatory expectation clearly.

4

Why It Matters

Explain why this matters to the organization, stakeholders, and mission. Keep it concise and outcome-focused.

5

Standards Alignment

NIST

ISO 42001

EU AI Act

SOC

Internal Policy

Select applicable standards.

6

Required Inputs

- List required inputs.
- Add additional inputs.
- Include sources, data, systems, or approvals.

7

Minimum Control Requirements

☐ Enter minimum requirement 1.

☐ Enter minimum requirement 2.

☐ Enter minimum requirement 3.

☐ Enter minimum requirement 4.

☐ Enter minimum requirement 5 (if applicable).

8

Enhanced Control Requirements

☐ Enter enhanced requirement 1.

☐ Enter enhanced requirement 2.

☐ Enter enhanced requirement 3.

☐ Enter enhanced requirement 4.

☐ Enter enhanced requirement 5 (if applicable).

9

Process Steps

1

Step 1

Describe the step.

→

2

Step 2

Describe the step.

→

3

Step 3

Describe the step.

→

4

Step 4

Describe the step.

→

5

Step 5

Describe the step.

10

Evidence / Artifacts

Required Artifact	Owner	Status
Add evidence artifact 1	Enter owner	Not Started
Add evidence artifact 2	Enter owner	In Progress
Add evidence artifact 3	Enter owner	Complete
Add evidence artifact 4	Enter owner	N/A

11

Related Templates

- [Template or Checklist Name 1](#)
- [Template or Checklist Name 2](#)
- [Template or Checklist Name 3](#)

12

Governance Notes

Add any implementation guidance, exceptions, assumptions, or additional notes here.

13

Approval / Sign-Off

Prepared by

Enter name / role

Reviewed by

Enter name / role

Approved by

Enter name / role

Date

MM / DD / YYYY

How to Use This Template



Define the control

Capture purpose, risk, and control action.



Assign ownership

Identify owners, contributors, and stakeholders.



Document evidence

List required artifacts and upload or link evidence.



Review on schedule

Follow the review cycle and update as needed.

24 Core Recipes Matrix

Station	Code	Recipe	Core Control	Owner
Foundation & Ownership	Ow	Head Chef Assignment Risk: Ownership Vacuum	Assign named AI governance owner, charter, RACI, escalation authority	EX / AG
	Pg	Kitchen Rules Risk: Policy Gaps	Set AI policy, acceptable use, prohibited use, and exception handling	LE / SE / AG
	Rc	Role Recipe Card Risk: Role Confusion	Define responsibilities across IT, Security, Legal, Privacy, Data, Procurement, HR, and business	AG
Data & Knowledge Controls	Sa	Approved Menu Only Risk: Shadow AI	Maintain approved tools register and sanctioned use pathways	IT / SE
	Di	Clean Ingredients Risk: Sensitive Data Exposure	Apply data classification and prompt handling restrictions	DA / PR / SE
	Pv	Source Provenance Check Risk: Untrusted or Poor-Quality Data	Track provenance, metadata, and approved knowledge sources	DA
	Rd	Retention & Disposal Recipe Risk: Over-Retention	Define AI-specific retention and deletion rules	PR / IT
	Kb	Knowledge Base Boundaries Risk: Unauthorized Retrieval	Enforce permission-aware retrieval and connector controls	IT / SE / DA
	Ev	Pre-Serve Evaluation Risk: Unsafe Deployment	Test performance, robustness, misuse, and bias before production	BU / SE / AG
Model & Tool Safety	Ss	Secret Sauce Lockdown Risk: Embedded Secrets Exposure	Use vaulting, secret scanning, and protected authentication	EN / SE
	Dt	Drift Tasting Risk: Behavioral Drift	Revalidate against benchmarks and review thresholds	BU / EN
	Vr	Vendor Pantry Review Risk: Third-Party AI Exposure	Perform AI-specific vendor, legal, and security due diligence	PC / SE / LE
Agent & Automation	Tp	Tool Permission Gate	Apply least privilege, scoped	IT / SE

Controls		Risk: Agent Overreach	tool access, and action thresholds	
	Hi	Human Before High Impact Risk: Unchecked Automation	Require human approval for high-impact actions	BU / AG
	Sb	Sandbox Before Service Risk: Unsafe Rollout	Use staging, pilots, rollback design, and controlled releases	EN / IT
	Ks	Kill Switch on the Counter Risk: Runaway Behavior	Enable emergency disablement and connector revocation	SE / IT
Decision & Human Oversight	Ex	Explain the Dish Risk: Opaque Outputs	Require rationale, notices, and traceability where appropriate	BU / LE
	Ea	Escalate Ambiguous Orders Risk: Harmful Outcomes	Define exception triggers and human escalation rules	BU
	Bt	Bias & Fairness Taste Test Risk: Unfair Outcomes	Conduct fairness review and remediation for high-impact uses	LE / BU / AG
	Hr	High-Risk Use Case Flag Risk: Sensitive Use Cases	Apply intake triage, risk tiering, and enhanced approval	AG
Assurance, Monitoring & Response	In	Full Kitchen Inventory Risk: Unknown AI Systems	Maintain AI system registry with owners, vendors, data, and status	AG / IT
	Lg	Kitchen Camera Logs Risk: Weak Auditability	Log prompts, tool calls, approvals, changes, exceptions, and incidents	SE / IT
	Ir	Burn Response Plan Risk: No AI Incident Handling	Create AI incident response playbook	SE / PR / LE / IT
	Qr	Quarterly Recipe Review Risk: Control Decay	Review metrics, open risks, exceptions, and maturity quarterly	AG / EX

Ownership Model and RACI

Primary roles

- Executive Sponsor (EX): accountably backs the program and clears roadblocks.
- AI Governance Lead (AG): operates the framework, intake, reviews, and reporting.
- IT / Platform Owner (IT): manages enablement, access, integration, and platform controls.
- Security (SE): enforces security controls, monitoring, and incident coordination.
- Privacy (PR): covers personal-data handling, retention, and privacy reviews.
- Legal / Compliance (LE): addresses regulatory, contractual, and policy interpretations.
- Data Owner / Governance (DA): owns data quality, provenance, and approved access.
- Business Owner (BU): owns the use case, benefits, and outcome accountability.
- Procurement / Vendor Risk (PC): performs third-party diligence and contract coordination.
- Engineering / Product (EN): implements technical safeguards and rollout design.

Sample RACI snapshot

Recipe	EX	AG	IT	SE	BU
Head Chef Assignment	A	R	C	C	I
Approved Menu Only	I	C	R	A	C
High-Risk Use Case Flag	C	A	I	C	R
Burn Response Plan	C	C	R	A	I

Escalation path: Business Owner -> AI Governance Lead -> Security/Privacy/Legal as needed -> Executive Sponsor for Tier 4 or exception approvals.

AI Use Case Intake and Risk Tiering

Required intake questions

- Business purpose and intended outcome
- AI capability type and provider
- Internal-only or external/customer-facing use
- Data sensitivity and regulated-data exposure
- Decision impact and human oversight requirement
- Automated actions or tool permissions
- Third-party/vendor dependence
- Applicable regulations or contractual obligations

Risk tier logic

Tier	Label	Use	Default expectation
1	Low	Internal productivity with low sensitivity	Standard controls and owner assignment
2	Moderate	Business workflow support with moderate data sensitivity	Documented review and evidence requirements
3	High	Sensitive data, consequential outputs, or customer impact	Enhanced controls and multi-function approval
4	Prohibited / Executive Review	Unsafe, disallowed, or materially high-risk use	Block or route to Executive Sponsor

Policy-to-Control Mapping Baseline

Use this baseline to turn policy language into minimum and enhanced operational controls.

Policy Theme	Required statement	Minimum control	Enhanced control	Evidence
Acceptable Use	Use approved tools only for approved purposes	Approved tools register and owner assignment	Periodic usage review and exception workflow	Tool list, approvals
Data Handling	Do not expose sensitive data without authorization	Classification and input restrictions	DLP, redaction, connector segmentation	Classification guidance, logs
Human Oversight	High-impact outputs require human review	Defined approval threshold	Dual approval or specialist sign-off	Review records
Vendor Review	Third-party AI providers require diligence	Security/legal review	Ongoing reassessment and contract safeguards	Vendor review pack
Logging & Monitoring	Material AI activity must be auditable	Prompt/tool/approval logging	Alerting, anomaly checks, and periodic review	Logs, review summaries
Incident Response	AI incidents must be escalated rapidly	AI incident categories and owner list	Playbooks, tabletop tests, lessons learned	Incident tickets, PIRs

AI Incident Response Playbook

Incident categories

- Harmful or misleading output
- Privacy breach or unauthorized data exposure
- Security exposure or embedded secret disclosure
- Model or agent drift causing unsafe behavior
- Unauthorized automation or unapproved integration
- Third-party vendor or service failure

Workflow

6. Detect and triage
7. Assess severity and impacted systems
8. Contain or disable affected AI activity
9. Escalate to Security, Privacy, Legal, and Executive Sponsor as required
10. Remediate and restore safe operation
11. Review root cause, evidence, and control improvements

Minimum evidence: incident summary, owner, timeline, impacted data/systems, containment action, recovery decision, lessons learned.

Governance Glossary

AI system: Any model, tool, agent, workflow, or embedded capability used to generate, classify, retrieve, recommend, or automate decisions.

Agent: An AI-enabled system that can invoke tools, call external systems, or take actions toward a task.

High-impact use case: A use case whose output can materially affect people, finances, legal posture, privacy, or safety.

Human oversight: A defined review or approval action by a responsible human before or after AI output is used.

Model drift: A measurable change in behavior, performance, or output quality over time that can affect reliability or safety.

Shadow AI: Use of AI tools or capabilities outside approved governance, visibility, or control.

Knowledge base: A collection of internal or external documents and data sources used to ground or enrich AI outputs.

Prohibited use: A use case that the organization forbids because the risk cannot be reduced to an acceptable level.

Standards Alignment Crosswalk

Reference only - not a legal certification claim.

Framework area	NIST AI RMF	ISO/IEC 42001	EU AI Act themes	SOC-style logic
Foundation & Ownership	Govern	Leadership, policy	Governance, QMS	Control environment
Data & Knowledge	Map / Manage	Data governance	Data governance	Confidentiality / Privacy
Model & Tool Safety	Measure / Manage	Lifecycle controls	Accuracy, robustness, cybersecurity	Processing integrity / Security
Monitoring & Response	Manage	Monitoring, improvement	Logging, oversight	Monitoring / Change management

AI Governance Evidence Register

- AI policy and approved tools list
- Use-case intake records and risk assessments
- AI system inventory
- Vendor review records
- Monitoring logs and exception records
- Incident reports and quarterly review decks